GUARDIAN MAIPO

Informe de desarrollo seguro y evaluación DevSecOps

Planta ficticia de agua potable · Caso docente de infraestructura crítica

EQUIPO	CONTEXTO
Daniel Silva	Operación y criterio sobre el impacto físico (rol propuesto).
Allen Ramirez	Desarrollo y automatización de pruebas (rol propuesto).
Antonella Mancilla	Auditoría de IA y documentación (rol propuesto).

Propósito

Crear una implementación académica original que muestre por qué conviene controlar secretos, entradas, dependencias y configuraciones antes de que un software pudiera acercarse a un servicio esencial. No controla equipos ni valida requisitos sanitarios.

Resultado comprobado en entorno local

VERIFICACIÓN	RESULTADO
Pruebas automáticas Python	12 de 12 aprobadas al construir esta versión.
Cuatro variantes sectoriales	Agua, energía, salud y transporte: 4 de 4 comprobaciones aprobadas.
Lector de registros	Se simuló una lectura de 0.70 mg/L; la credencial ficticia no se imprimió.
GitHub Actions	Tres workflows configurados en la raíz; ejecución remota pendiente de verificar.

Alcance real de esta evidencia: los resultados citados fueron producidos localmente; no se atribuyen al nuevo equipo ejecuciones, capturas o pull requests de terceros.

1. Arquitectura y fronteras de confianza

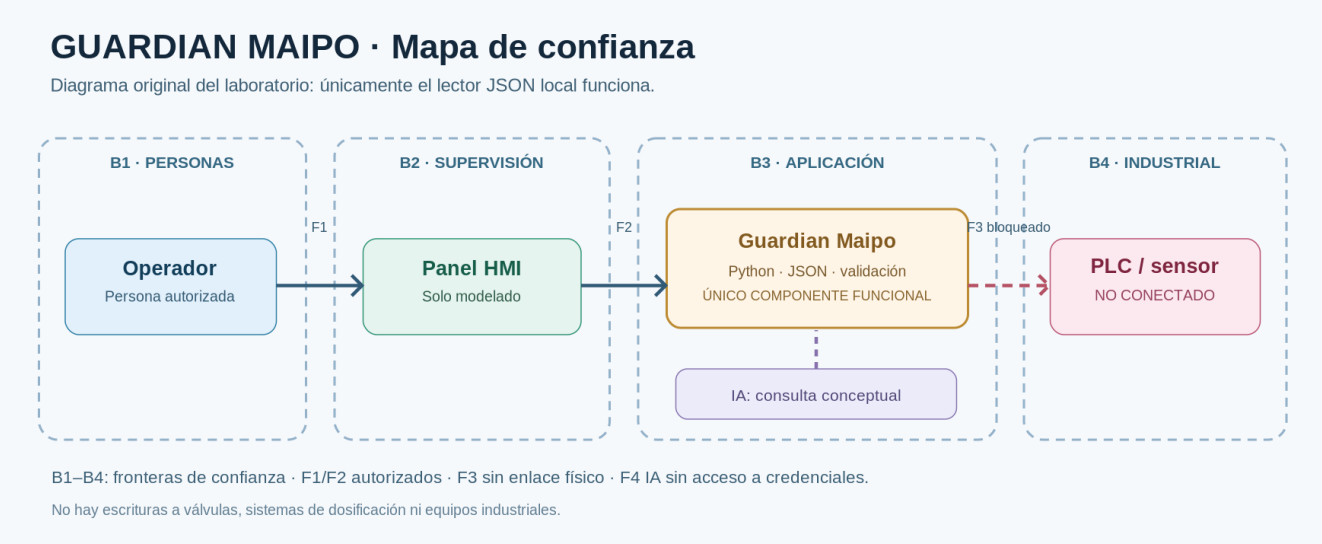


Figura 1. Diagrama original editable en docs/arquitectura/diagrama.mmd. La única pieza ejecutable es el lector de JSON ficticio.

Tres amenazas que prioriza el equipo

AMENAZA STRIDE	POSIBLE EFECTO EN UNA PLANTA REAL	CONTROL
A1 · Suplantación y filtración	Acceso no autorizado al panel; se compromete la confiabilidad de la supervisión.	Gitleaks, variable de entorno, rotación del secreto si fuese real.
A2 · Manipulación y privilegios	Valores o comandos alterados inducen respuestas incorrectas.	Validación de entradas, Semgrep y prohibición de shell.
A3 · Divulgación, denegación y privilegios	Exposición del panel o pérdida de su disponibilidad.	Trivy config, regla MAIPO-NET-001 y red limitada.

La elección se basó en STRIDE y una escala cualitativa de probabilidad e impacto. A1 y A2 recibieron 9 puntos orientativos (3×3); A3 recibió 6 (2×3). No se trata de un análisis de riesgo industrial certificado.

2. Seguridad integrada al desarrollo

Controlamos tres superficies distintas

SUPERFICIE	HERRAMIENTAS	EVIDENCIA ESPERADA EN GITHUB
Código propio	Gitleaks · Semgrep	Análisis de secretos y patrones; registros JSON del run.
Código externo	Trivy vulnerabilidades · OSV-Scanner	Revisión de dependencias conocidas y sus versiones.
Infraestructura estática	Trivy config + regla de red del laboratorio	Detección de una política de panel excesivamente abierta.
Inventario de software	SBOM CycloneDX generada por Trivy	Archivo reports/sbom.cdx.json como artefacto de Actions.

Una prueba falla a propósito, otra pasa

El workflow 03 - Ejercicio 1 rojo a verde genera, dentro de un directorio temporal del runner, un archivo ficticio con un secreto de prueba. Gitleaks debe terminar rojo por encontrarlo. Con la opción corregida, crea una referencia a PLC_PASSWORD y demuestra un resultado verde sin mostrar el valor almacenado como GitHub Secret.

Reglas de trabajo

No se desactivan detectores para obtener verde. Los pasos de seguridad guardan informes y una compuerta final bloquea el workflow si cualquier análisis obligatorio no termina correctamente. Los escáneres binarios están fijados a versiones y descargas verificadas con SHA-256; las acciones estándar de GitHub están referenciadas por commit.

Resultados locales observados

12/12 tests de unidad (valores válidos y erróneos, entrada de sensor restringida, secreto ausente, etc.). 4/4 escenarios estáticos (agua, energía, salud, transporte). Los análisis externos de Gitleaks, Semgrep, Trivy y OSV todavía requieren ejecución y comprobación en GitHub.

3. Auditoría responsable de una propuesta de IA

El material del taller presenta un supuesto cambio de IA que pretende acelerar una consulta. Para el proyecto nuevo se conserva como un caso descrito para revisión, no como programa vulnerable ejecutable.

PREGUNTA OBLIGATORIA	OBSERVACIÓN / DECISIÓN
¿Existe ese paquete?	Se menciona plc_helper_utils sin procedencia acreditada. No instalar hasta verificar su identidad y origen.
¿Qué hace con la entrada?	Se pretende concatenar texto externo para construir un comando. Rechazar: el lector propio valida entradas y no ejecuta shell.
¿Se apaga alguna defensa?	La propuesta desactiva verificación TLS con verify=False. Rechazar.
¿Adónde van los datos?	TELEMETRIA no tiene destino, autorización ni finalidad justificadas. Rechazar transmisión.

Dictamen

RECHAZAR. Que una propuesta funcione no demuestra que sea segura. El equipo exige dependencias de procedencia verificada, entradas validadas, certificado TLS comprobado, destinos autorizados y revisión humana antes de incorporar cambios.

Explicación para el operador

«Esta modificación podría alterar la confianza en la información del turno y enviar registros a alguien no autorizado. Como la propuesta no acredita su seguridad ni el destino de los datos, no la incorporamos al sistema».

Actividad sobre inyección de instrucciones

La presentación del curso incluye una práctica controlada de IA en un laboratorio autorizado. Este equipo dispone de instrucciones y una ficha para registrar resultados, pero no declara haber superado niveles ni realizado intentos sin capturas propias.

4. Entrega, trazabilidad y pendientes

CRITERIO DE RÚBRICA	PUNTOS	UBICACIÓN
Amenazas y efecto físico	25	docs/amenazas/analisis.md; diagrama original
Controles con ejecución real	25	.github/workflows/seguridad.yml; evidencias/VALIDACION.md
Hallazgos y decisiones	20	ENTREGABLE.md; seguimiento de responsables
Auditoría del parche de IA	20	docs/auditoria-ia/veredicto.md
Explicación comprensible	10	docs/exposicion/guion.md

No se debe declarar completado antes de GitHub

- URL de un run rojo por secreto ficticio y de un run verde con corrección.
- URL de integración aprobada y enlace al reporte de escaneo de seguridad.
- SBOM generada por Trivy y descargada como artefacto de Actions.
- Pull request de auditoría de IA abierta pero no fusionada.
- Fotografía de un dibujo efectivamente hecho por el grupo, si la evaluación presencial la exige.
- Ratificación de asignación de roles y registro de responsables.

Fuentes

Presentación “Taller DevSecOps sobre Infraestructura Crítica” y “Guía del facilitador v2” de la Universidad Bernardo O’Higgins. Referencia temática: repositorio de Miguel Briceño y equipo. Herramientas: GitHub Actions, Gitleaks, Semgrep OSS, Trivy, OSV-Scanner y CycloneDX. Consulta de fuentes extendida en docs/REFERENCIAS.md.

Advertencia: para evaluar la seguridad real de una instalación industrial se requeriría autorización del titular, validación del fabricante, ensayos de confiabilidad, segmentación y políticas de recuperación; no están cubiertos por esta simulación.